# PHISHING EMAIL FORENSICS

A Comparative Forensic Analysis of a Legitimate Email and a Phishing Email

**Prepared by: Omoneka Philomena Ekhaizor**

Date: September 2026

# Table of Contents

## 1. Objective

The objective of this project is to demonstrate practical email forensics skills by investigating two real emails received in a live inbox: one legitimate notification and one phishing attempt impersonating a well-known brand. The investigation examines raw email headers, authentication mechanisms (SPF, DKIM, DMARC), sending infrastructure, and embedded links to determine the true origin and intent of each message, and to illustrate the analytical process a security analyst follows when triaging a suspicious email.

## 2. Scope

This report covers two case studies:

- Case Study 1: A recruitment notification email from “RedCloud”, sent via the Teamtailor applicant tracking platform, used as the legitimate control sample.
- Case Study 2: An email impersonating Amazon, requesting account verification, used as the malicious/phishing sample.

Both emails were analyzed using the same methodology, allowing for a direct side-by-side comparison of the technical indicators that distinguish a legitimate message from a phishing message.

## 3. Tools Used

- Notepad - raw email source (.eml) inspection
- Gmail “Show Original” - raw header and source extraction
- MX Toolbox (Domain Health / Analyze Headers) - domain and mail server health checks
- AbuseIPDB - IP reputation and WHOIS lookups
- VirusTotal (urlscan/URL analysis) - URL and redirect-chain reputation scanning
- RIPE / WHOIS databases - IP ownership verification

## 4. Methodology

For each email, the following steps were carried out in sequence:

- Preserve and view the raw message source (headers and body) rather than the rendered client view.
- Extract and record the From, To, Subject, Date, Message-ID, Return-Path and Received header chain.
- Evaluate the consolidated Authentication-Results header for SPF, DKIM and DMARC verdicts.
- Identify the originating IP address and check its ownership, usage type and abuse history.
- Run the sending domain through a domain health checker to review DNS, mail server and blacklist status.

- Extract any links in the email body and trace their full redirect chain to the final landing page, scanning each hop for reputation flags.
- Compare all findings for internal consistency (do the From domain, Return-Path domain, sending IP and body links all agree?) and reach a conclusion.

# 5. Case Study 1: Legitimate Email - “RedCloud” Talent Pool Notification

## 5.1 Rendered Email (Inbox View)

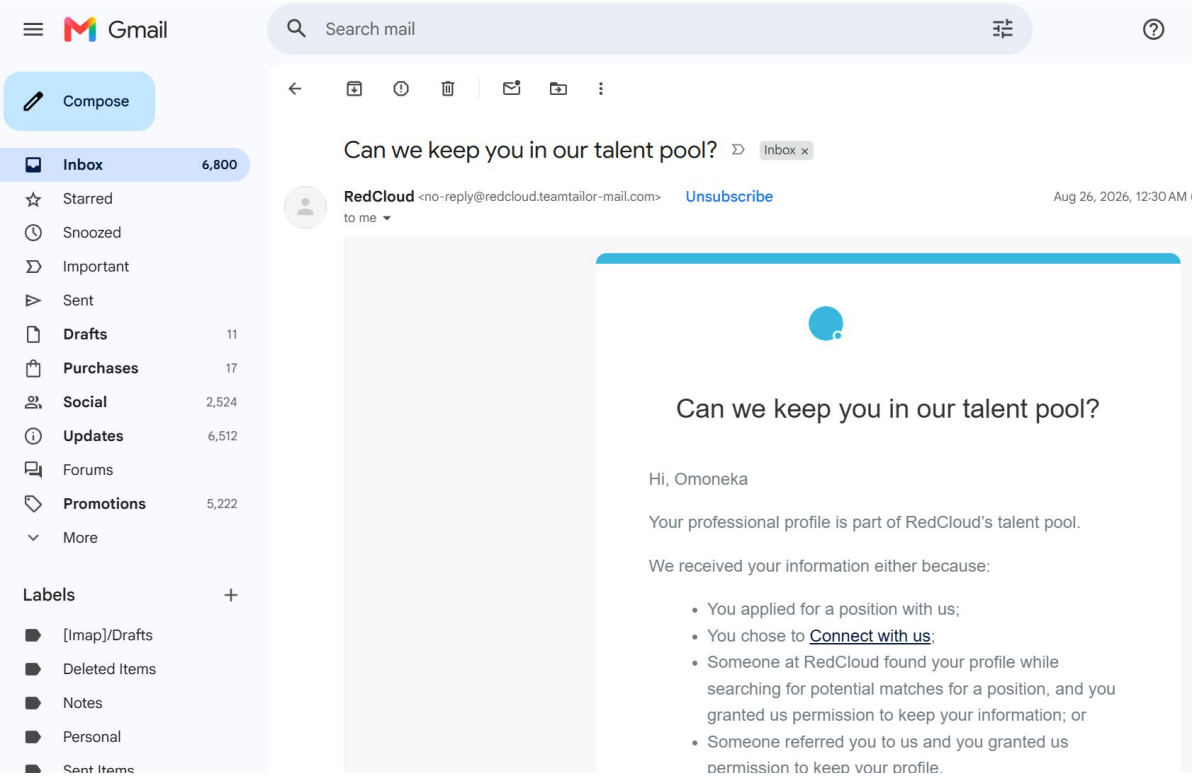



*Figure 1. Email as it appeared in the recipient's Gmail inbox.*

## 5.2 Email Body (Excerpt)

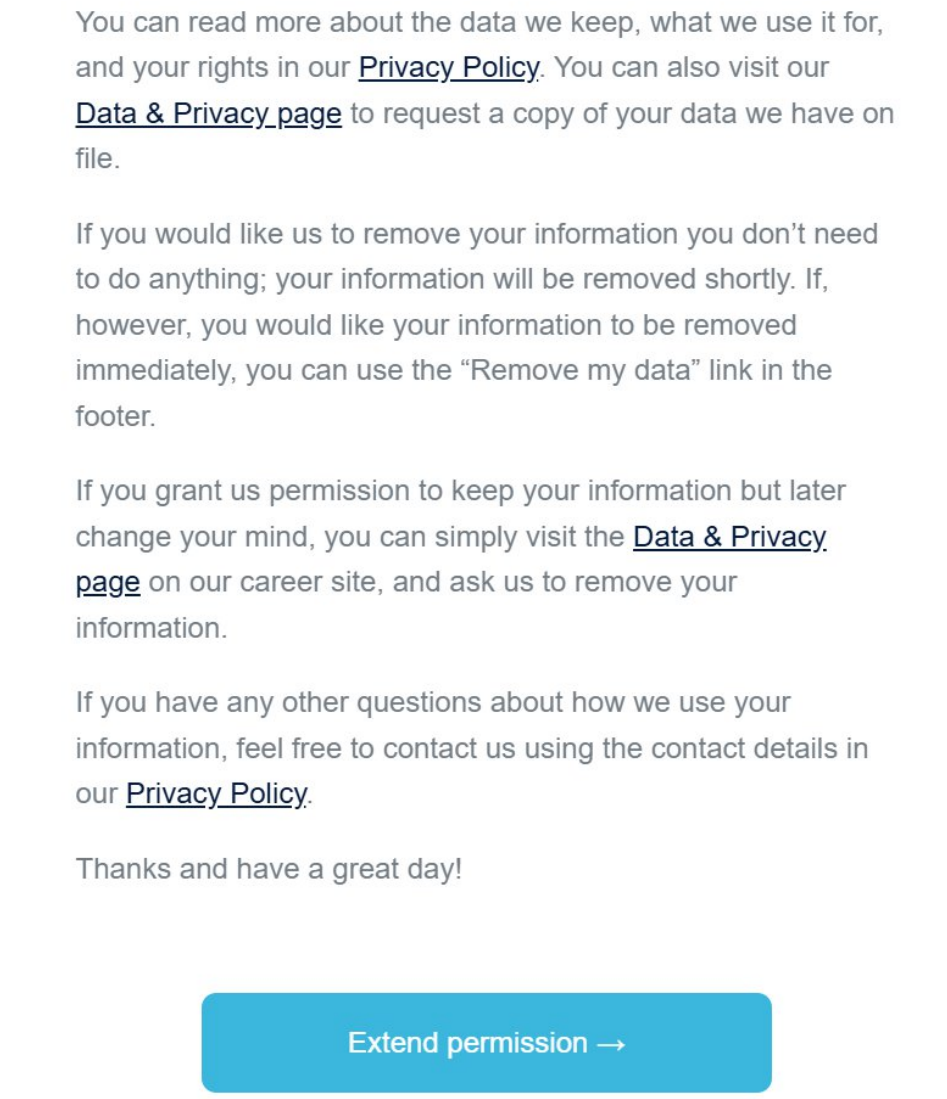



*Figure 2. Footer/body excerpt showing data-privacy language and call-to-action, consistent with a legitimate ATS notification.*

## 5.3 Header Identity Block

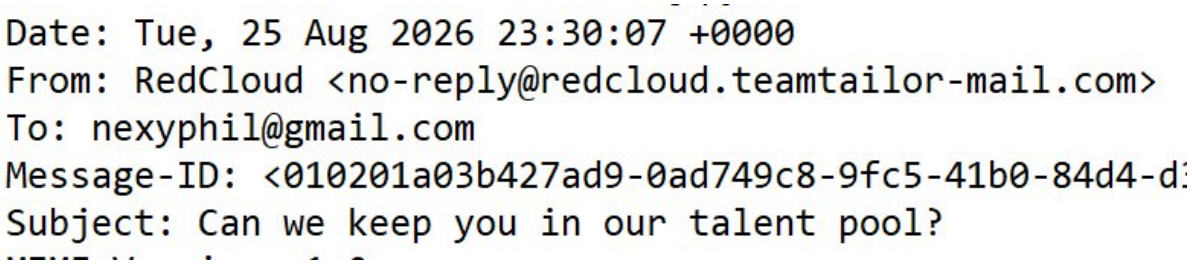



*Figure 3. Date, From, To, Message-ID and Subject headers.*

## 5.4 Return-Path and Received Chain

```
Return-Path: <010201a03b427ad9-0ad749c8-9fc5-41b0-84d4-d3c900a2cca7-000000@s.teamtailor-mail.com>
Received: from c149-245.smtp-out.eu-west-1.amazonses.com (c149-245.smtp-out.eu-west-1.amazonses.com. [76.223.149.245])
        by mx.google.com with ESMTPS id ffacd0b85a97d-482e2787e30si906936f8f.91.2026.08.25.16.30.07
        for <nexyphil@gmail.com>
        (version=TLS1_3 cipher=TLS_AES_128_GCM_SHA256 bits=128/128);
        Tue, 25 Aug 2026 16:30:08 -0700 (PDT)
```

*Figure 4. Return-Path and Received header showing the originating IP address 76.223.149.245.*

## 5.5 Authentication Results

```
ARC-Authentication-Results: i=1; mx.google.com;
       dkim=pass header.i=@teamtailor-mail.com header.s=zc7qdfn557aganoljndo53w
       dkim=pass header.i=@amazonses.com header.s=shh3fegwg5fppqsuzphvschd53n6i
       spf=pass (google.com: domain of 010201a03b427ad9-0ad749c8-9fc5-41b0-84d4
       dmarc=pass (p=REJECT sp=NONE dis=NONE) header.from=teamtailor-mail.com
```

*Figure 5. ARC-Authentication-Results showing DKIM, SPF and DMARC all passing.*

## 5.6 IP Reputation and Ownership

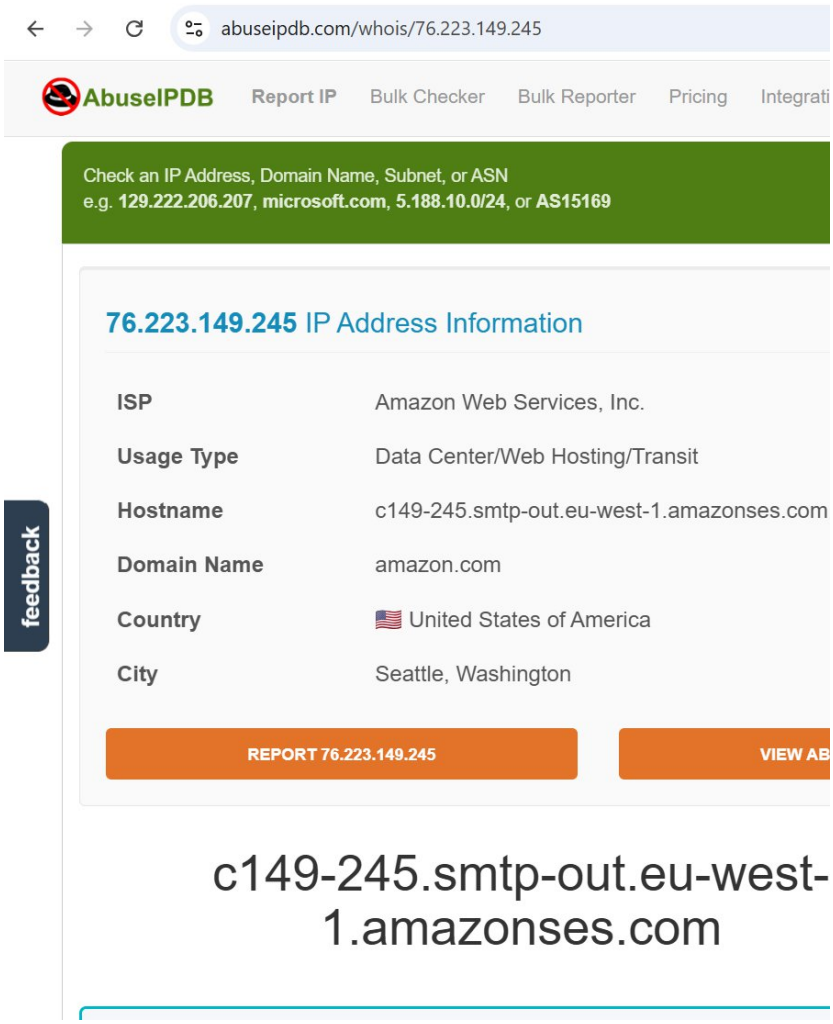



*Figure 6. AbuseIPDB record confirming the sending IP belongs to Amazon Web Services, Inc.*

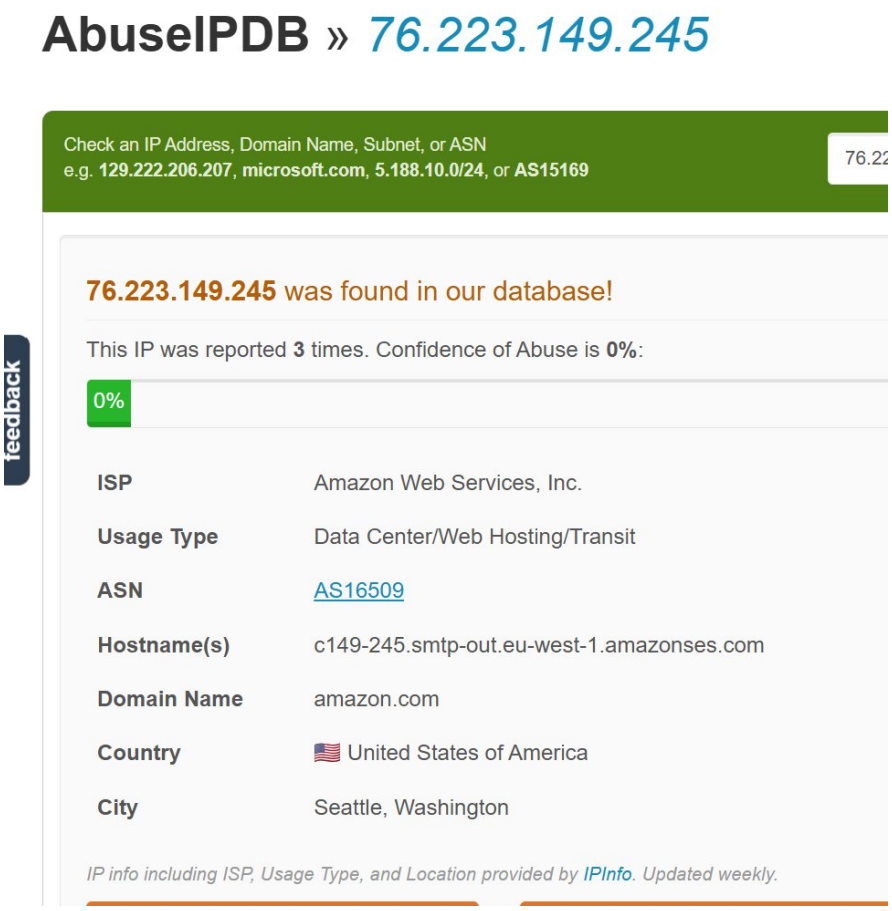



*Figure 7. AbuseIPDB abuse-confidence score of 0% for 76.223.149.245.*

## 5.7 Domain Health Check

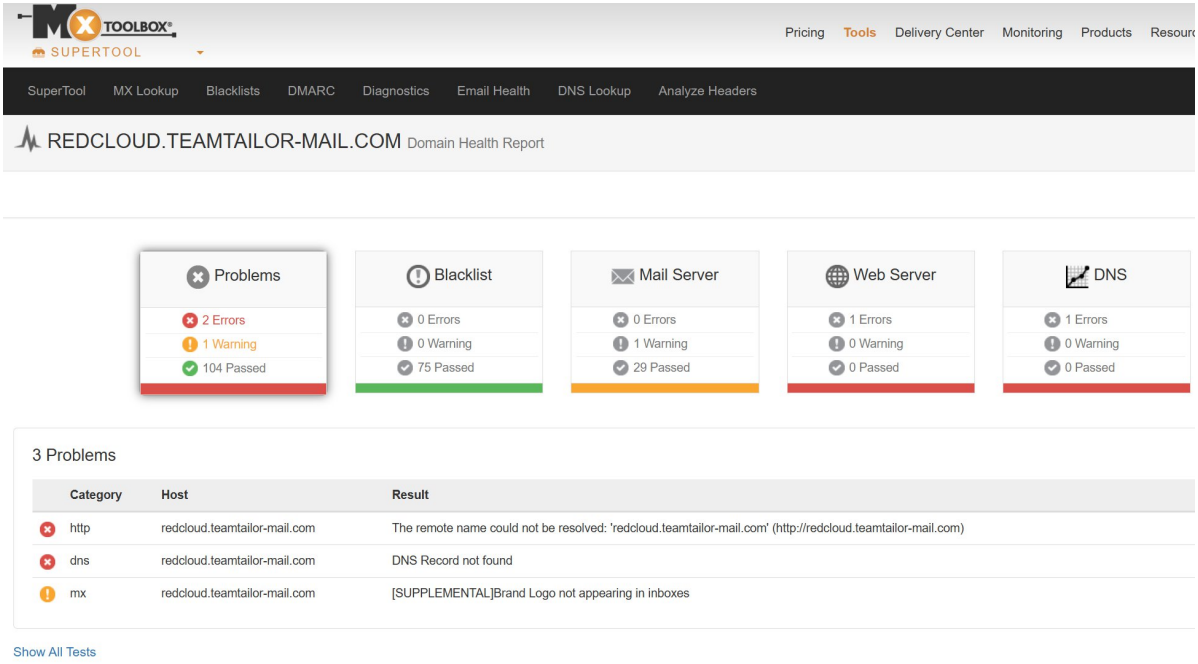



*Figure 8. MX Toolbox domain health report for redcloud.teamtailor-mail.com. The DNS/HTTP errors relate to this being a sending-only subdomain with no public website - it is not a red flag.*

## 5.8 Body Link Scan

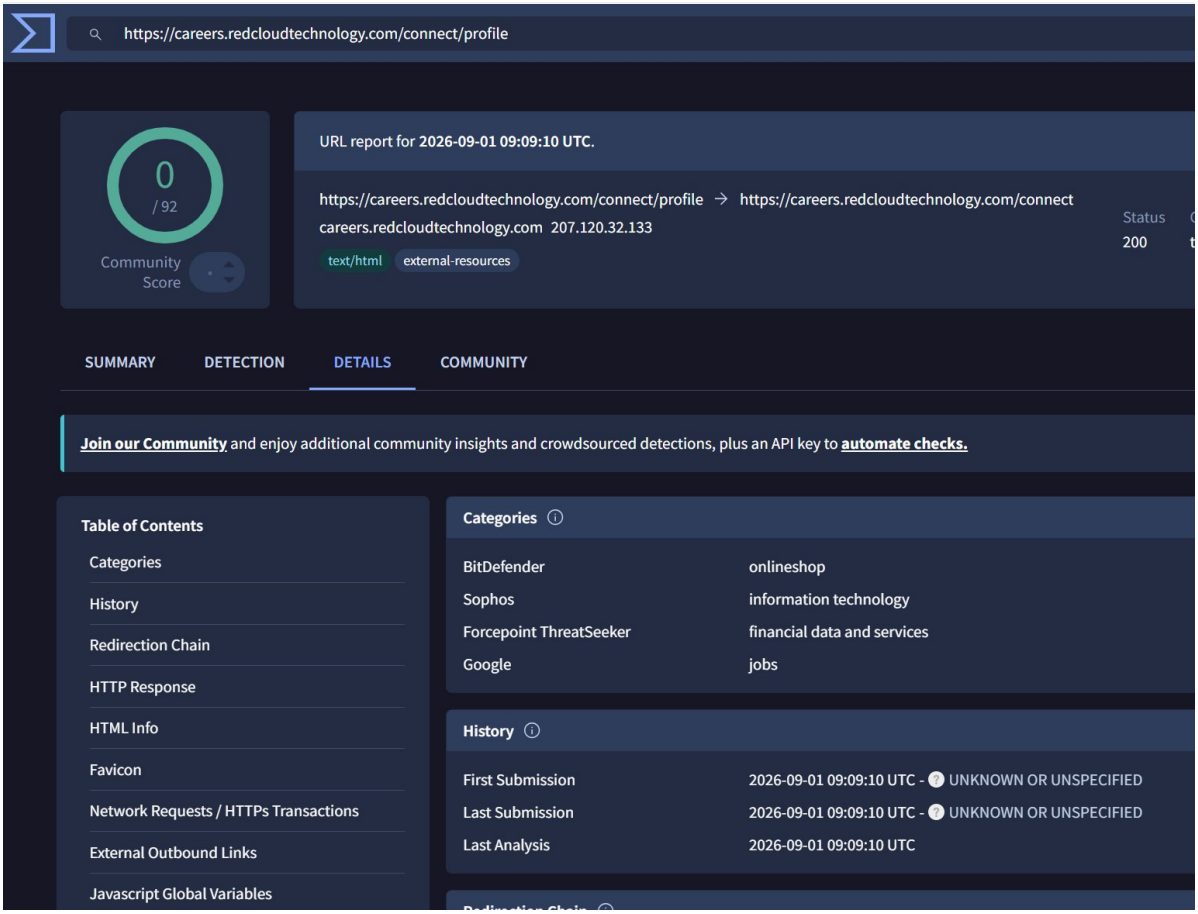



*Figure 9. VirusTotal scan of the profile link in the email body: 0/92 detections, resolving consistently to careers.redcloudtechnology.com.*

## 5.9 Findings Summary

| Indicator | Observation |
|---|---|
| **SPF / DKIM / DMARC** | All pass. DKIM signed by both teamtailor-mail.com and amazonses.com. |
| **Sending infrastructure** | Amazon SES (76.223.149.245), a recognized legitimate email service provider. |
| **IP reputation** | 0% abuse confidence on AbuseIPDB; IP is officially allocated to Amazon Web Services. |
| **Domain consistency** | From, Return-Path and body links all align to the teamtailor-mail.com / redcloudtechnology.com family. |
| **Body link scan** | 0/92 detections; URL resolves to the expected careers.redcloudtechnology.com domain. |

| Indicator | Observation |
|---|---|
| **Content analysis** | Personalized greeting, no urgency or threat language, standard recruitment CRM messaging. |
| **Conclusion** | This email is LEGITIMATE. It is an automated recruitment notification sent through Teamtailor on behalf of RedCloud Technology. |

# 6. Case Study 2: Phishing Email - Fake “Amazon Account Verification”

## 6.1 Rendered Email (Inbox View)

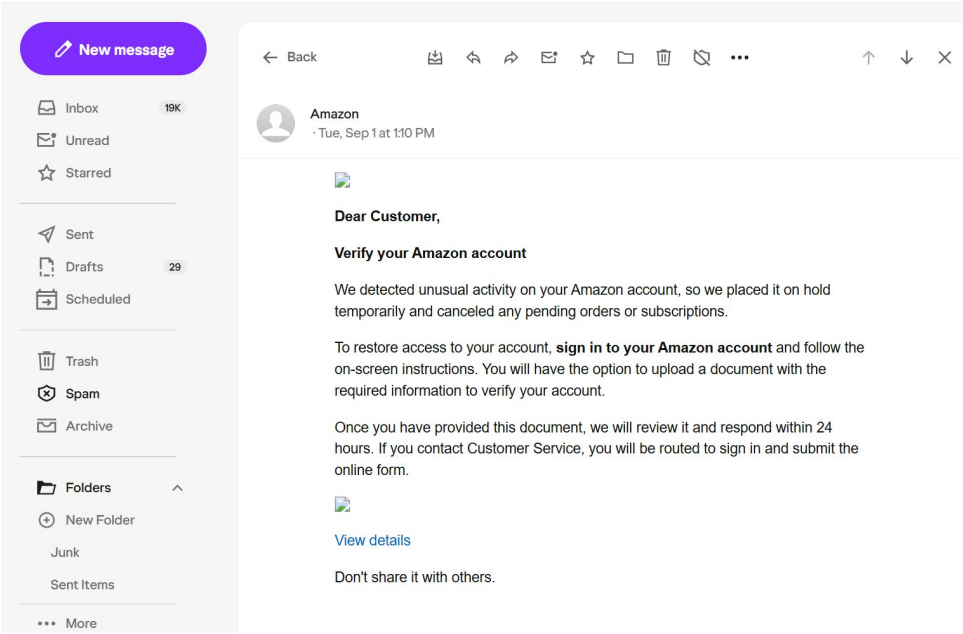



*Figure 10. Email as rendered in the inbox, impersonating Amazon and requesting account verification.*

## 6.2 Header Identity Block

```
From: "Amazon" <account_update@amazon.com>
Message-ID: 554M8OgO87G641_3Anv1P463tdI8035016.V43325264ODMO0572mC-25A6UaH04Z4f8@yahoo.com
Date: Tue, 01 Sep 2026 14:21:11 +0300
Subject: Account Recovery: Sign-in and Verify your Amazon account Tue, 01 Sep 2026 14:21:11 +0300
MIME-Version: 1.0
```

*Figure 11. From, Message-ID, Date and Subject headers. The From address claims amazon.com, but the Message-ID domain is yahoo.com - an inconsistency.*

## 6.3 Return-Path, Originating IP and Authentication Results

```
Return-Path: <account_update@amazon.com>
X-Originating-Ip: [46.23.51.233]
Received-SPF: fail (domain of amazon.com does not designate 46.23.51.233 as permitted sender)
Authentication-Results: mta.yahoo.com;
 dkim=unknown;
 spf=fail smtp.mailfrom=amazon.com arc_overridden_status=NOT_OVERRIDDEN;
 dmarc=fail(p=QUARANTINE) header.from=amazon.com arc_overridden_status=NOT_OVERRIDDEN;
X-Apparently-To: nekaphil@yahoo.com; Tue, 1 Sep 2026 12:10:38 +0000
```

*Figure 12. Return-Path, X-Originating-IP and Authentication-Results showing SPF fail, DKIM unknown, and DMARC fail.*

## 6.4 IP Reputation and Ownership

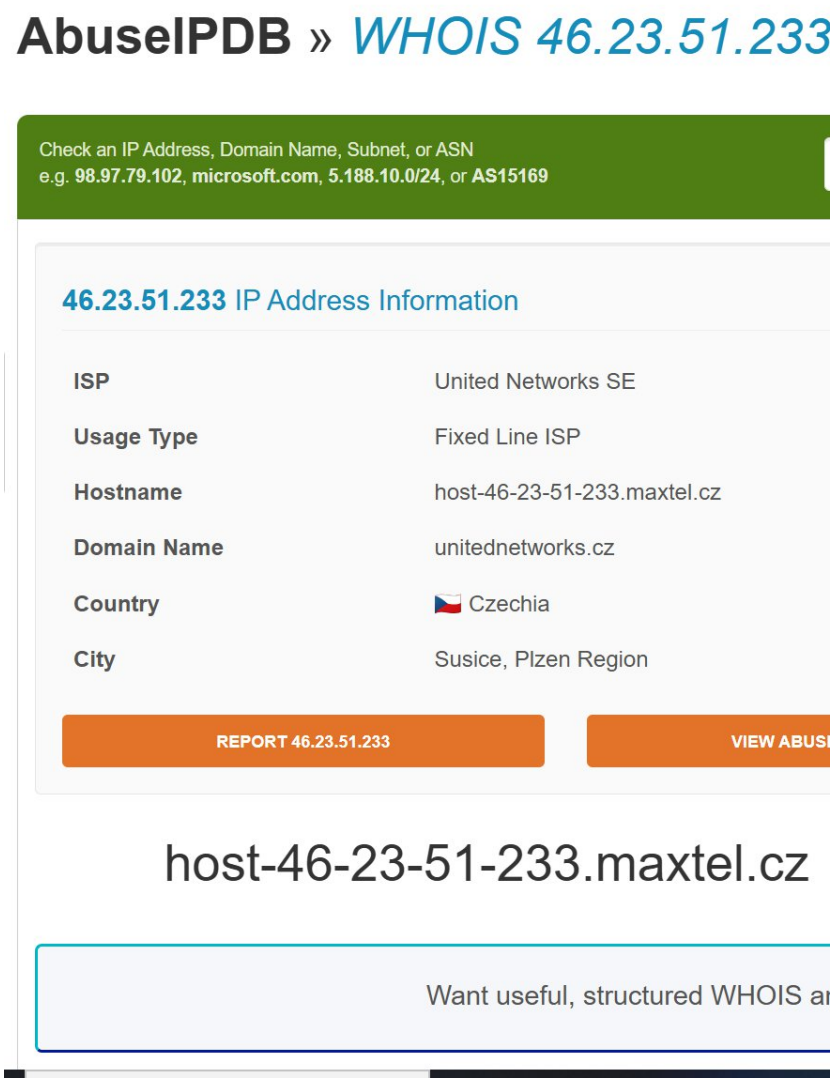



*Figure 13. AbuseIPDB WHOIS for 46.23.51.233, showing the IP belongs to a residential/fixed-line ISP in Czechia - unrelated to Amazon.*

## 6.5 Amazon's Real Domain Health (for comparison)

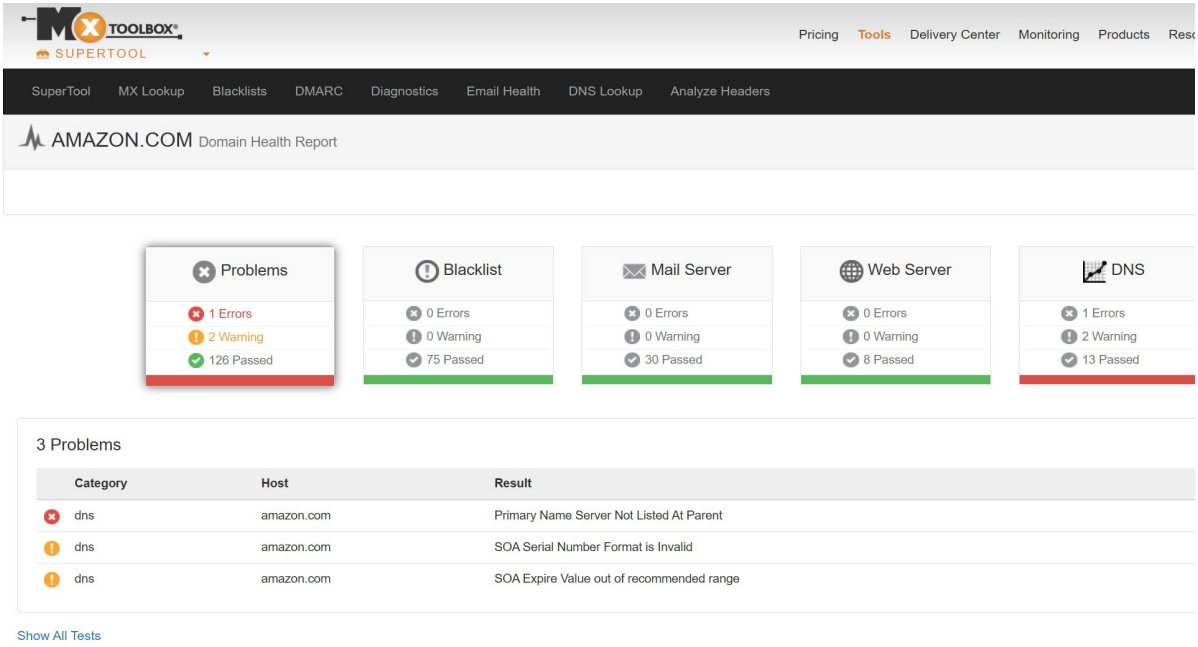



*Figure 14. MX Toolbox domain health for the genuine amazon.com, included to show the real domain's infrastructure is unrelated to the IP that actually sent this email.*

## 6.6 Body Link - Redirect Chain Analysis

The verification link in the email body does not lead directly to a suspicious address; it first passes through a trusted-looking Google URL, which is why an automated scan of the surface link alone returns a clean result. Tracing the full redirect chain reveals the true destination:

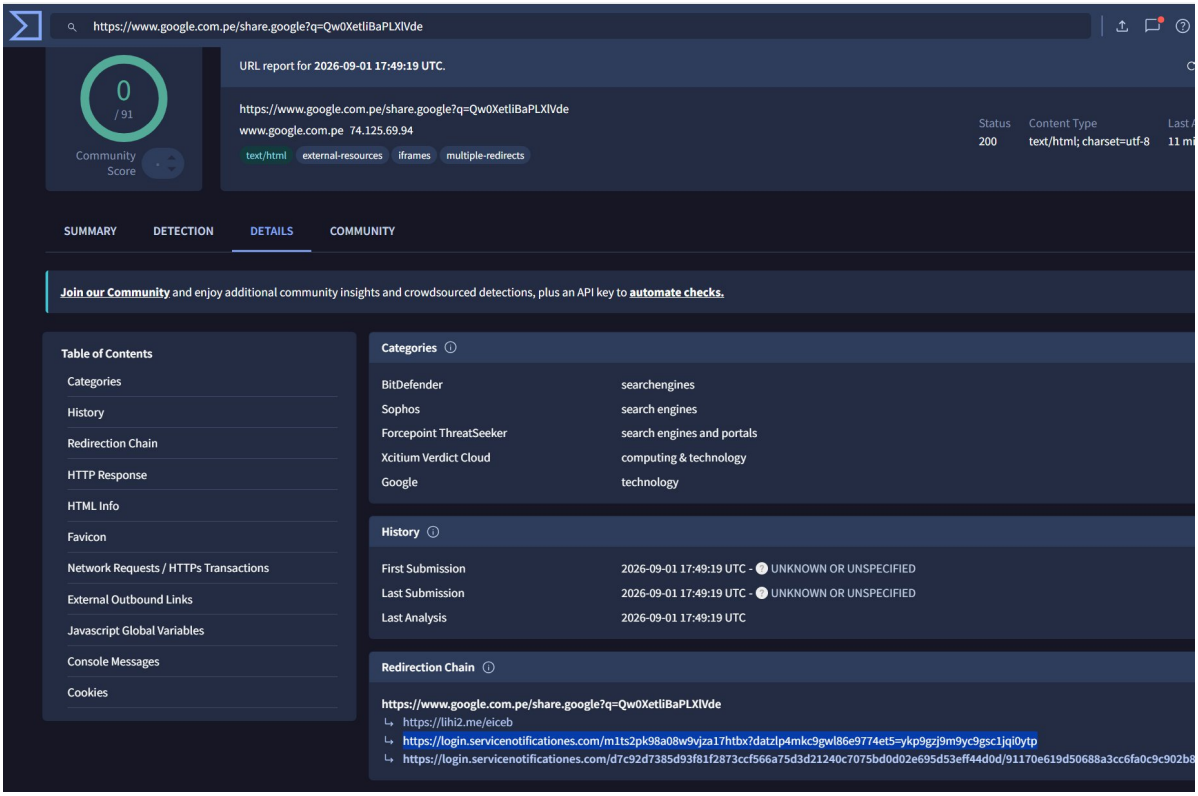



*Figure 15. VirusTotal redirection chain: google.com.pe (share link) -> lihi2.me (URL shortener) -> login.servicenotificationes.com (final landing page).*

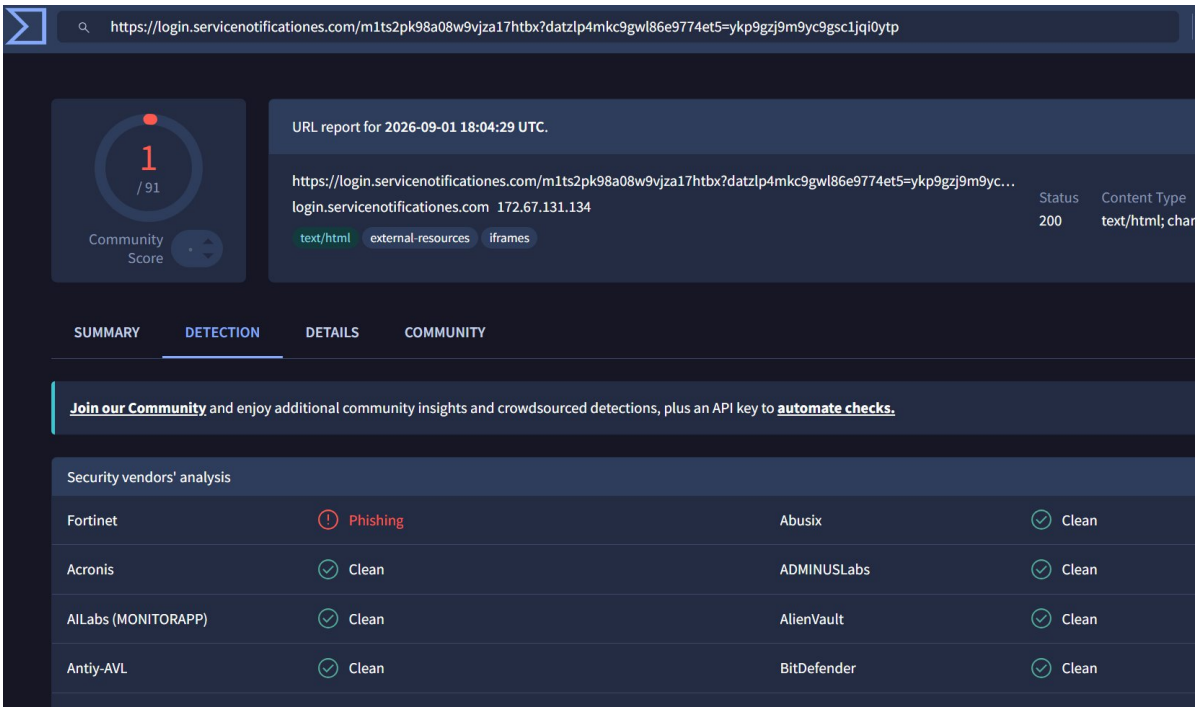



*Figure 16. VirusTotal scan of the final landing page, login.servicenotificationes.com - flagged as Phishing by Fortinet.*

## 6.7 Findings Summary

| Indicator | Observation |
|---|---|
| **SPF / DKIM / DMARC** | SPF fail, DKIM unknown, DMARC fail (p=QUARANTINE) - complete authentication failure. |
| **From vs Message-ID** | From claims account_update@amazon.com; Message-ID domain is yahoo.com - mismatch indicating spoofing. |
| **Sending IP** | 46.23.51.233 - a residential ISP address in Susice, Czechia, with no relationship to Amazon. |
| **Redirect chain** | 3-hop redirect: Google share link, URL shortener (lihi2.me), then a typosquat domain (servicenotificationes.com). |
| **Final destination scan** | login.servicenotificationes.com flagged as Phishing by Fortinet on VirusTotal. |
| **Content analysis** | Generic “Dear Customer” greeting, urgency language (“account on hold”), pressure to sign in immediately. |
| **Conclusion** | This email is a CONFIRMED PHISHING attempt impersonating Amazon to harvest account credentials. |

## 7. Comparative Analysis

The table below places both cases side by side across every check performed, illustrating how consistent authentication and infrastructure evidence separates a legitimate sender from an impersonation attempt.

| Check | Case 1: RedCloud (Legitimate) | Case 2: Fake Amazon (Phishing) |
|---|---|---|
| **SPF** | Pass | Fail |
| **DKIM** | Pass (teamtailor-mail.com & amazonses.com) | Unknown / not verifiable |
| **DMARC** | Pass (p=REJECT) | Fail (p=QUARANTINE) |
| **Sending IP** | 76.223.149.245 - Amazon SES (legitimate ESP) | 46.23.51.233 - residential ISP, Czechia |
| **AbuseIPDB** | 0% abuse confidence, AWS-owned | IP unrelated to Amazon; consumer ISP block |
| **From / Return-Path alignment** | Consistent (teamtailor-mail.com family) | From claims amazon.com; Message-ID on yahoo.com |
| **URL scan (surface link)** | 0/92 - clean | 0/91 - clean (masks real destination) |
| **Redirect chain** | None - direct link | 3 hops: Google share link to URL shortener to typosquat login page |
| **Final destination** | N/A | login.servicenotificationes.com - flagged Phishing (Fortinet) |
| **Email content tone** | Personalized, no urgency | Generic greeting, urgency / account-hold pressure |
| **Conclusion** | Legitimate recruitment notification | Confirmed phishing attempt |

## 8. Key Takeaways

- Authentication headers (SPF/DKIM/DMARC) are the fastest first check, but a pass on all three should still be cross-checked against sender identity and content - and a fail should never be taken at face value without checking why.
- A clean automated scan of a surface-level link is not sufficient evidence of safety; attackers deliberately chain trusted redirect services (URL shorteners, legitimate share links) to defeat first-pass scanning. The full redirect chain must be traced to the final landing page.
- IP WHOIS/ownership lookups are highly effective at exposing spoofed “From” addresses - a claimed brand whose mail originates from an unrelated residential ISP is a strong indicator of impersonation.
- Inconsistencies between headers that should agree (From domain, Return-Path domain, Message-ID domain) are a reliable, low-effort red flag.
- Content and tone analysis (urgency, generic greetings, threat of account suspension) remains a useful supporting signal alongside technical evidence.

## 9. Recommendations

- Enforce DMARC at p=reject on organizational domains to prevent spoofed mail from reaching inboxes.
- Train users to check the final destination of links (hover/inspect) rather than trusting the visible or first-hop domain.
- Encourage verification of unexpected account-related emails through the official app or website rather than by clicking embedded links.
- Deploy or tune email gateway rules to flag mismatches between From, Return-Path and Message-ID domains.
- Report confirmed phishing infrastructure (sending IPs, redirect domains) to abuse databases such as AbuseIPDB to support community defense.

## 10. Conclusion

This project demonstrated a full email forensics workflow applied to two contrasting real-world samples. The legitimate RedCloud/Teamtailor email showed full authentication alignment, a reputable sending infrastructure (Amazon SES) and consistent domains throughout. The phishing email impersonating Amazon showed the opposite: failed authentication, a spoofed sender identity, an unrelated residential sending IP, and a multi-hop redirect chain designed to evade automated detection and ultimately confirmed as phishing by a security vendor. Applying a consistent methodology to both samples made it possible to reach a confident, evidence-based conclusion in each case - which is the core skill this project set out to demonstrate.